RVU MENTORSHIP CAMP

# THE FIELD KIT

## بداية أوضح وشغل مرتب

قالب تقرير وقائمة لفهم التطبيق وتجهيزك قبل الكامب
موارد تعليمية بالعربي والإنجليزي

---

**ARABIC**

قالب تقرير أمني

قائمة فهم الـTarget

تجهيزك قبل الكامب

**ENGLISH**

Security report guide

Target understanding checklist

Before the camp

# قالب تقرير أمني

قالب كتابة ومراجعة املأ الأقسام بأدلة اختبارك الفعلي واحذف أي قسم غير مناسب المثال أدناه تعليمي وليس تقريرا عن ثغرة في خدمة حقيقية

## ١ عنوان يصف السلوك والأثر

اكتب نوع الخلل + الوظيفة المتأثرة + الأثر المثبت
مثال للصياغة غياب فحص ملكية الطلب يسمح لحساب اختباري بعرض طلب حساب اختباري آخر

## ٢ ملخص

اذكر السلوك الطبيعي والسلوك الذي لاحظته والشروط اللازمة وضح هل يتطلب حسابا أو دورا معينا

## ٣ النطاق وبيئة الاختبار

حدد الأصل والمسار والطريقة HTTP method والدور الذي استخدمته
سجل وقت الاختبار ونسخة التطبيق إن كانت معروفة
استخدم أسماء مثل Account A وAccount B للحسابات التي تملكها
احذف Cookies وTokens والبيانات الشخصية من النسخة المعدة للمشاركة

## ٤ خطوات إعادة الاختبار

1 جهز الحسابات والموارد المطلوبة داخل النطاق المصرح به
2 نفذ العملية الطبيعية من صاحب المورد وسجل الطلب المرجعي Baseline
3 غير متغيرا واحدا من جلسة الحساب الآخر مع توضيح المورد المطلوب
4 قارن النتيجة المتوقعة بالنتيجة الفعلية
5 تحقق من البيانات أو الحالة المحفوظة على السيرفر HTTP 200 وحده لا يثبت الخلل

## ٥ الأدلة

لكل خطوة الطلب المهم الجزء الدال من الاستجابة والحساب المستخدم وضح الربط بين معرف المورد وصاحبه
استخدم صورا واضحة ومقطعا قصيرا عند الحاجة ولا تجعل الفيديو بديلا للخطوات المكتوبة

## ٦ الأثر وحدود الاستنتاج

اذكر ما أثبته تحديدا قراءة تعديل تنفيذ إجراء أو تغيير حالة فرق بين الدليل والاحتمال لا تستنتج الوصول لكل المستخدمين من تجربة محدودة ولا تضع رقم خسائر بلا دليل

## ٧ توصية معالجة

اربط التوصية بسبب الخلل في مثال ملكية الطلب تحقق على السيرفر من صلاحية المستخدم على المورد عند كل عملية حساسة مع اختبارات تمنع الرجوع للخلل

## مراجعة قبل الإرسال

☐ الهدف والاختبار داخل النطاق
☐ الخطوات قابلة للتكرار من شخص آخر
☐ النتيجة المتوقعة والفعلية واضحتان
☐ الأسرار والبيانات الخاصة محذوفة من النسخة المشتركة
☐ الأثر مرتبط بالأدلة والتقييم لا يتجاوز ما أثبته
☐ العنوان والملخص لا يكرران نصا عاما لا يصف الحالة

# قائمة فهم الـTarget

استخدم القائمة لبناء صورة واضحة عن التطبيق قبل زيادة الأدوات الناتج المطلوب خريطة صغيرة + أسئلة مرتبة + دليل لكل اختبار

## ١ حدود الشغل

☐ دون الأصول المسموحة والاستثناءات وقواعد الحسابات والطلبات
☐ تأكد أن أي نطاق أو رابط جديد داخل النطاق قبل التفاعل معه
☐ حدد حسابات الاختبار التي تملكها والأدوار المتاحة

## ٢ الاستخدام الطبيعي

☐ جرب الوظائف الأساسية كما يفعل المستخدم إنشاء عرض تعديل إلغاء
☐ تابع الطلبات والاستجابات في Burp Suite
☐ حدد أين تخزن الجلسة وكيف تتغير أثناء الدخول والخروج
☐ ارسم خطوات الـWorkflow والحالات المسموحة للانتقال بينها

## ٣ خريطة التطبيق

أنشئ جدولا بالأعمدة الوظيفة | المسار | طريقة الطلب | الدور | المورد | الأثر المحتمل | ملاحظات
☐ اجمع المسارات المرتبطة بالوظائف المهمة من حركة التطبيق والـJavaScript والتوثيق المتاح
☐ اربط كل معرف بالمورد وصاحبه
☐ دون الوظائف الحساسة مثل استرجاع الحساب وتغيير البريد وإدارة الأدوار والدفع
☐ اكتب ما لا تفهمه بدل افتراضه

## ٤ فرضيات قابلة للاختبار

☐ هل يفحص الدور وملكية المورد في كل خطوة؟
☐ هل يؤكد السيرفر السعر والكمية والحالة بنفسه؟
☐ هل يتغير السلوك بين الواجهة ومسار API المقابل؟
☐ هل يمكن الانتقال لحالة قبل استكمال شروطها؟
☐ لكل فرضية Baseline تغيير واحد نتيجة متوقعة ودليل مطلوب

## ٥ الأولوية والمراجعة

☐ ابدأ بالوظائف الحساسة والأسئلة التي تملك حسابات وموارد مناسبة للتحقق منها
☐ سجل نتائج الاختبارات السلبية أيضا
☐ ميز بين أثر حقيقي على السيرفر وتغيير محلي في الواجهة
☐ احتفظ بخطوة تالية واضحة قبل التوقف

وجود أدوات أكثر لا يعني خريطة أوضح قياس التقدم هل تعرف ماذا تختبر ولماذا وما الدليل الذي سيؤكد النتيجة؟

# تجهيزك قبل الكامب

قائمة للاستعداد وليست اختبار قبول لو نقطة ناقصة جهزها أو ناقشها معايا في الانترفيو

## الأساسيات

☐ أقدر أشرح الفرق بين Request وResponse
☐ أعرف وظيفة URL وMethod وHeaders وBody وStatus code
☐ فاهم فكرة الحساب والجلسة والفرق بين الدخول والصلاحيات
☐ اشتغلت بالبرب داخل بيئة تدريب
☐ أعرف أتحرك بين الملفات والمجلدات وأشغل أمرا بسيطا في Terminal

## الجهاز والاتصال

☐ كمبيوتر مناسب شاحن وإنترنت ثابت
☐ Burp Suite ومتصفح تجريبي جاهزان
☐ Discord يعمل والصوت واضح
☐ مساحة لحفظ الملاحظات والتسجيلات والملفات التدريبية عند الحاجة
☐ أختبر مشاركة الشاشة قبل أول جلسة
☐ أراجع تعليمات RVU Commerce في مستودعه قبل التثبيت وأتبع متطلبات النسخة المستخدمة في الكامب

## الوقت

☐ راجع مواعيد الاثنين والخميس ٧:٣٠–١٠:٣٠ مساء بتوقيت مصر
☐ خصص 5 لـ 7 ساعات تطبيق أسبوعيا بجانب السيشنز
☐ احتفظ بوقت لتجميع الأسئلة قبل المتابعة الفردية كل أسبوعين

## طريقة توثيق المحاولة

اكتب لكل محاولة كنت متوقع إيه؟ غيرت إيه؟ حصل إيه فعلا؟ إيه الدليل؟ إيه اللي مش واضح؟ إيه الخطوة التالية؟

## قبل الانترفيو

جهز وصفا مختصرا لمستواك مثالا لمحاولة توقفت فيها هدفك من الكامب والوقت المتاح مش محتاج تحفظ إجابات المطلوب نفهم نقطة البداية

# Security report guide

Use your actual test evidence to complete each section and remove irrelevant sections. The example is educational, not a claim about a real service.

## 1. Title

Describe the flaw, affected feature and demonstrated impact.
Example wording: Missing order ownership validation allows one test account to view another test account’s order.

## 2. Summary

Describe expected behavior, observed behavior and prerequisites, including the account role required.

## 3. Scope and environment

Identify the asset, endpoint, HTTP method, role, test time and application version if known. Label accounts you own Account A and Account B. Remove cookies, tokens and personal information from shared evidence.

## 4. Reproduction steps

1. Prepare the required accounts and resources in the authorized environment.
2. Perform the normal action as the resource owner and capture a baseline.
3. Change one variable using the other account’s session, identifying the requested resource.
4. Compare the expected and actual outcomes.
5. Verify returned data or stored server-side state; HTTP 200 alone proves nothing.

## 5. Evidence

For each relevant step, include the request, meaningful response excerpt and acting account. Establish resource ownership. Add a readable screenshot or short video when useful; video should complement written reproduction steps.

## 6. Impact and limits

State the access or state change you demonstrated. Separate evidence from hypotheses. Do not generalize a limited test to all users or invent financial loss.

## 7. Remediation

Address the underlying cause. For the order ownership example: validate server-side permission for the resource on every sensitive action and add regression coverage.

## Before submitting

☐ The asset and testing are in scope.
☐ Another person can reproduce the steps.
☐ Expected and actual outcomes are explicit.
☐ Secrets and private data are removed from shared evidence.
☐ Impact and severity follow the evidence.
☐ The title and summary describe this specific finding.

# Target understanding checklist

Build a small map, prioritized questions and evidence for each test before expanding your toolchain.

## 1. Boundaries

☐ Record allowed assets, exclusions, account rules and request limits.
☐ Verify newly discovered assets are in scope before interacting.
☐ Identify your test accounts and available roles.

## 2. Normal behavior

☐ Use core features: create, read, update and cancel.
☐ Follow requests and responses in Burp Suite.
☐ Identify session storage and changes during login and logout.
☐ Map workflow steps and allowed state transitions.

## 3. Application map

Create columns for: feature, path, method, role, resource, potential impact and notes.
☐ Map relevant paths from application traffic, JavaScript and available documentation.
☐ Link identifiers to resources and owners.
☐ Identify sensitive features such as recovery, email changes, roles and payments.
☐ Record uncertainties instead of assuming answers.

## 4. Testable hypotheses

☐ Are roles and resource ownership checked at each step?
☐ Does the server validate prices, quantities and state?
☐ Do the UI and corresponding API enforce the same rules?
☐ Can a state transition happen before its prerequisites?
☐ Give each test a baseline, one controlled change, expected outcome and evidence requirement.

## 5. Prioritize and review

☐ Start with sensitive features you can verify using appropriate test accounts and resources.
☐ Record negative results too.
☐ Distinguish server-side impact from local interface changes.
☐ Leave yourself a clear next step before stopping.

Measure progress by whether you can explain what you are testing, why it matters and which evidence would confirm the result.

# Before the camp

A preparation checklist, not an admission test. Work on missing items or discuss them with me during the interview.

## Foundations

☐ Explain the difference between a request and a response.
☐ Understand URLs, methods, headers, bodies and status codes.
☐ Understand accounts, sessions, authentication and authorization.
☐ Intercept a request with Burp Suite in a training environment.
☐ Navigate files and folders and run a simple terminal command.

## Setup

☐ Computer, charger and stable internet.
☐ Burp Suite and a testing browser ready.
☐ Working Discord access and clear audio.
☐ Space for notes, recordings and training files when needed.
☐ Screen sharing tested before the first session.
☐ Read RVU Commerce setup instructions in its repository and follow the version used in the camp.

## Time

☐ Review the Monday and Thursday schedule: 7:30–10:30 PM, Cairo time.
☐ Set aside 5–7 practice hours weekly, in addition to live sessions.
☐ Collect questions for the private review every two weeks.

## Document an attempt

Record: What did I expect? What did I change? What actually happened? What evidence supports it? What remains unclear? What should I try next?

## Before the interview

Prepare a short description of your level, one attempt where you got stuck, your goal and your available time. The purpose is to understand your starting point, not memorize answers.